Week 3: Linux Logs, Sysmon, auditd and Snort Setup

Theory Notes, Developing Basic Understanding in SOC

Question 4. Explain how Snort works as an IDS/IPS. What is the difference between Snort in IDS mode versus IPS mode? When would a SOC use each?

What is Snort

Snort is a free and open source tool that watches network traffic and checks it against a set of rules. It is now maintained by Cisco. When a packet matches a rule, Snort does whatever the rule says, such as raising an alert or dropping the packet. It can also be used just to sniff packets or to log them.

How Snort works

Step	Part	What happens
1	Packet capture	Packets are read from the network interface
2	Packet decoder	The headers of Ethernet, IP, TCP, UDP and ICMP are decoded
3	Preprocessors	Fragments and TCP streams are put together and the traffic is cleaned up, so attackers find it harder to hide
4	Detection engine	Each packet is compared with the rules loaded from files such as local.rules
5	Output	Alerts are written to the console or to log files, or the packet is dropped in IPS mode

IDS mode and IPS mode

Point	IDS mode	IPS mode
Placement	Sits on the side and receives a copy of the traffic, for example from a SPAN port or tap	Sits in the path, so all traffic goes through it
Action	Only alerts and logs	Can alert, drop or reject packets
Effect on traffic	No effect, traffic is not delayed	Adds a small delay, and a failure can block the network
False positives	Only gives a wrong alert	Can block genuine traffic
Rule actions	alert, log, pass	drop, reject and sdrop, along with the IDS actions
Example command	`snort -A console -q -c /etc/snort/snort.conf -i enp0s3`	Needs inline setup with a DAQ module such as afpacket or NFQ

When a SOC uses each mode

- IDS mode is used when we want visibility without any risk to the network. It is also the safe choice for testing and tuning new rules, and for places where business traffic must never be interrupted.
- IPS mode is used at the edge of the network or in front of important servers, when the rules are well tuned and trusted. It can block known exploits, scans and malware traffic automatically.

- A common approach is to run a new rule in IDS mode first, look at the alerts for a while, and move it to IPS mode only when the false positives are low.